Riepilogo Definitivo — Archibald PWA Compliance

Meeting Komet Italia — 14 Aprile 2026

Aggiornato: 2026-04-05

Premessa: Decisioni Prese in Questa Sessione

Questi elementi cambiano l'audit precedente (2 aprile) e riducono il numero di gap aperti:

Decisione	Impatto
SMTP → mailto	Rimuove il "blocco critico SMTP". La security-alert-service scrive nel DB. Nessun sub-processor email. Nessuna variabile SMTP nel VPS.
Komet = Titolare del trattamento	Il data mapping, le basi giuridiche del trattamento, le nomine degli autorizzati e le richieste degli interessati (artt. 15-22) sono obblighi di **Komet**, non nostri. Francesco come Responsabile deve: DPA, Registro dei Trattamenti come Responsabile, misure di sicurezza.
MFA Device Trust (30 giorni)	Aggiunto dopo PR #13. Risolve la friction OTP quotidiana: token crittografico (SHA-256) persistito in DB, il client lo presenta al login successivo e salta l'OTP per 30 giorni. Migration 049 in prod. Tutti i ruoli facoltativi.

Sezione 1 — Inventario Completo dello Stato

1A — Implementato e Deployato in Produzione (commit fd9f3421 + device trust, 2026-04-05)

Cosa	File / Migration
JWT revocation via Redis (`revokeToken` + `isTokenRevoked`, TTL dinamico dal claim `exp`)	`src/db/redis-client.ts`, `src/middleware/auth.ts`
MFA TOTP completo (setup, confirm, verify, recovery codes 8× bcrypt)	`src/services/mfa-service.ts`, `src/routes/auth.ts`
MFA TOTP: **volontario per tutti i ruoli**; attivazione da Profilo → Sicurezza	`src/routes/auth.ts`
MFA Device Trust: skip OTP per 30 giorni (`rememberDevice` checkbox, SHA-256 in DB)	Migration 049, `src/db/repositories/mfa-trusted-devices.ts`, `src/routes/auth.ts`, `frontend/src/components/MfaVerifyStep.tsx`
Audit log immutabile (`REVOKE UPDATE, DELETE` a livello DB)	Migration 046
GDPR erase: 10 campi su `agents.customers` + 9 campi su `shared.sub_clients`, guard ordini attivi, auditato	`src/db/repositories/gdpr.ts`, `src/routes/admin.ts`

GDPR portabilità: `GET /api/admin/customers/:id/export` → archivio JSON strutturato	`src/routes/admin.ts`, `src/db/repositories/gdpr.ts`
RBAC: 4 ruoli (`admin/ufficio/agent/concessionario`), 7 moduli per-utente	Migration 047, `src/routes/admin.ts`
Credenziali ERP cifrate AES-256-GCM in DB (PBKDF2, IV random, non estraibile)	`src/services/password-encryption-service.ts`
Backup PostgreSQL: pg_dump + gzip + rclone → Hetzner fsn1, rotazione 30	`backup/backup.sh`, `backup/Dockerfile`
Rate limiting: login 5/15min, refresh 20/60min, mfa-verify 10/15min, mfa-setup 5/15min, mfa-confirm 5/15min	`src/routes/auth.ts`
Security alerts: audit log + link `mailto:` (nessun SMTP esterno)	`src/services/security-alert-service.ts`
CORS restrictive (whitelist-based) + Helmet CSP	`src/server.ts`
Input validation Zod su tutte le route critiche	`src/routes/admin.ts`, `src/routes/auth.ts`
`last_activity_at` su `agents.customers` (aggiornato su submit-order)	Migration 048, `src/operations/handlers/submit-order.ts`
Retention scheduler: notifica settimanale per clienti inattivi > 24 mesi	`src/db/repositories/retention.ts`, `src/main.ts`
`AccessManagementPage` (frontend): ruoli, moduli, MFA status, whitelist	`frontend/src/pages/AccessManagementPage.tsx`
`MfaSetupPage` (frontend): setup TOTP con setupToken come Bearer	`frontend/src/pages/MfaSetupPage.tsx`
Procedura incident response P1/P2/P3 (notifica Titolare 24h, Garante 72h)	`docs/compliance/incident-response-procedure.md`
Pacchetto contrattuale completo (5 documenti)	`docs/contracts/`
Redis con `--requirepass` nel docker-compose	`docker-compose.yml`
CI: npm audit, TypeScript check, **npm test backend**, build Docker su ogni push	`.github/workflows/ci.yml`
Guard `actorId !== targetId` su PATCH /users/:id (no auto-blocco admin)	`src/routes/admin.ts`

1B — Implementato in PR #13 (feat/compliance-nis2-gdpr, mergiato e deployato 2026-04-05)

> *Tutti i fix A.1–A.12 sono stati implementati nel branch `feat/compliance-nis2-gdpr` e sono in produzione. La tabella è conservata per riferimento storico — ogni voce è ora ✅.*

#	Cosa	Stato attuale	File da modificare
A.1	Rimozione nodemailer → security alert via audit_log + mailto. **URGENZA ALTA: in prod gli alert vengono silenziosamente scartati perché SMTP_HOST è vuoto.**	`nodemailer` ancora in `package.json`, alert non funzionanti	`security-alert-service.ts`, `config.ts`, `main.ts`, `package.json`
A.2	Rate limit `/mfa-setup` e `/mfa-confirm` (5/15min) + **fix secret TOTP in chiaro**	Non presente; `/mfa-setup` ritorna `{ uri, secret }` — il `secret` raw non va mai esposto, solo `uri`	`src/routes/auth.ts`
A.2b 🆕	`createMfaTokenMiddleware()` imposta `username: ''` → QR code senza label nell'authenticator	`username: ''` hardcoded nel middleware	`src/routes/auth.ts`
A.3	Disclaimer GDPR su campi nota liberi (frontend)	Non presente	`frontend/src/pages/CustomerProfilePage.`
A.4	Verifica Google Fonts: nessun `<link>` in `index.html` — verificare se fonts sono caricati da CSS/JS. Se sì, self-host.	Cache Workbox in `vite.config.ts` ma no link in `index.html`	`frontend/vite.config.ts`, eventuale CSS
A.5	GDPR erase esteso a `shared.sub_clients`: `ragione_sociale`, `telefono`, `telefono2`, `telefono3`, `email`, `email_amministraz`, `pers_da_contattare`, `cod_fiscale`, `partita_iva`	Erase copre solo `agents.customers`	`src/db/repositories/gdpr.ts`
A.6	Endpoint portabilità dati `GET /api/admin/customers/:id/export`	Non presente	`src/routes/admin.ts`, `src/db/repositories/gdpr.ts`
A.7	Retention scheduler BullMQ: notifica admin per clienti inattivi > 24 mesi	Nessun `retention.ts`, nessun cron	`src/db/repositories/retention.ts` (nuovo `src/main.ts`
A.8 🆕	CI workflow: aggiungere step `npm test` per il backend — attualmente zero test girano in CI	Manca step in `ci.yml`	`.github/workflows/ci.yml`

A.9 🆕	`gdpr.spec.ts` troppo superficiale: verifica solo che `withTransaction` sia chiamato, non che il SQL sia eseguito	Test passa anche con corpo della transaction vuoto	`src/db/repositories/gdpr.spec.ts`
A.10 🆕	`/api/admin/audit-log` non ritorna `total` count → paginazione frontend impossibile	Manca `COUNT(*)` nella response	`src/routes/admin.ts`
A.11 🆕	`docker-compose.yml` ha `DATABASE_PATH=/app/data` (residuo SQLite, fuorviante)	Legacy env var	`docker-compose.yml`
A.12 🆕	Guard `actorId !== targetId` mancante su `PATCH /users/:id` per i role change — admin può bloccarsi fuori	Nessuna protezione	`src/routes/admin.ts`

1C — Da Fare sull'Infrastruttura (Fase B del Piano)

#	Cosa	Note
B.1	Creare bucket Hetzner Object Storage `archibald-backups` (fsn1)	console.hetzner.com → Object Storage
B.2	Variabili `.env` VPS — **`REDIS_PASSWORD`** ✅ **configurata**, **`CORS_ORIGINS`** ✅ **configurata**. Da aggiungere ancora: `SECURITY_ALERT_EMAIL`, `HETZNER_BUCKET`, `HETZNER_S3_ENDPOINT`, `HETZNER_ACCESS_KEY`, `HETZNER_SECRET_KEY`	Nessuna variabile SMTP necessaria.
B.3	✅ Migration 046 + 047 + 048 + 049 applicate in produzione (2026-04-05)	Runner automatico al riavvio backend post-deploy
B.4	✅ Branch mergiato (PR #13 + device trust) + deploy automatico completato 2026-04-05	5 container healthy, nessun errore di startup
B.5	Test post-deploy parziali: **MFA setup admin** ❌, **backup manuale Hetzner** ❌ (bucket non ancora creato), login agenti ❌	Da completare entro 8 aprile

1D — Da Fare a Livello Documentale (Fase C del Piano)

#	Cosa	Note
C.1	Registro dei trattamenti (Art. 30.2 GDPR) come Responsabile	1 pagina, template nel piano
C.2	DPIA screening (10 domande) + nota su JWT in localStorage come rischio accettato	Conclusione probabile: DPIA non obbligatoria

C.3	Compilare i 45 placeholder nei contratti	Sessione 2h, vedi lista nel piano
C.4	Aggiornare sub-processor list: rimuovere SMTP, aggiungere nota TIA per FedEx	`docs/compliance/sub-processors.md`
C.5	Informativa agenti: cosa viene tracciato e perché (Art. 4 Statuto Lavoratori)	Aggiungere clausola all'informativa privacy esistente

---

Sezione 2 — Delta Audit (2 aprile) vs Piano (4 aprile)

Gap risolti dalle nuove decisioni

Gap nell'audit	Risolto come
SMTP provider ❌ (blocco critico)	Decisione mailto — SMTP eliminato, nessun sub-processor email
Sub-processor list incompleta ⚠️	Lista completa: Hetzner + FedEx (+ Dropbox opzionale Fresis)
Autorizzazioni scritte per autorizzati ❌	Responsabilità di Komet (Titolare): gli agenti sono loro collaboratori, non nostri. Noi garantiamo accesso solo a persone autorizzate tramite RBAC.
Data inventory / data mapping ❌	Come Responsabile, non serve un data mapping completo — serve il Registro dei Trattamenti come Responsabile (C.1), che descrive cosa trattiamo per conto di Komet. Il mapping delle proprie categorie di dati è obbligo del Titolare (Komet).

Gap coperti dal piano

Gap nell'audit	Coperto in
Rate limit /mfa-setup e /mfa-confirm ⚠️	Piano A.2
Retention scheduler ⚠️	Piano A.7
Disclaimer campi note ❌	Piano A.3
Google Fonts ⚠️	Piano A.4 (con verifica preliminare)
JWT in localStorage ⚠️	Documentato in DPIA screening (C.2) come rischio accettato per PWA B2B
Diritti interessati portabilità ⚠️	Piano A.6
Cancellazione sub-clienti ⚠️	Piano A.5
Registro dei trattamenti ❌	Piano C.1
DPIA screening ❌	Piano C.2
Monitoraggio agenti Art. 4 SL ❌	Piano C.5

Gap nell'audit NON ancora nel piano (da aggiungere o valutare)

Gap	Priorità	Azione
Analisi del rischio NIS2 documentata (non solo SLA, ma risk assessment formale)	🟡	Da fare post-meeting come documento separato. Il DPIA screening copre parzialmente.
Penetration test (SLA ha placeholder `[DA INSERIRE]`)	🟡	Pianificare per Q3 2026. Da concordare con Komet se è clausola contrattuale o raccomandazione.
Registrazione ACN come soggetto NIS2	🟢	Condizionale: solo se Formicola Francesco rientra come "soggetto importante". Verificare con consulente NIS2 post-meeting. Molto probabilmente non applicabile a una persona fisica con un solo cliente.
Polizza cyber risk	🟢	Da valutare entro 2026 (non bloccante per il 14 aprile).
Addendum Gebr. Brasseler / conflitto di legge	🟡	Se Brasseler firma il MSA come parte, serve consulenza legale. Se firma solo Komet Italia, nessun problema. **Da chiarire con Komet prima del meeting.**

Sezione 3 — Meeting Komet 14 Aprile: Cosa Portare

Documenti da FIRMARE al meeting

1. **`MSA-contratto-saas.md`** → 2 copie stampate, firmate da entrambe le parti
   - *Prerequisito: tutti i placeholder compilati, incluso canone mensile*
2. **`DPA-art28-gdpr.md`** → 2 copie stampate, firmate da entrambe le parti
   - *Prerequisito: P.IVA Formicola, P.IVA Komet, email DPO/privacy Komet*

Documenti da CONSEGNARE a Komet

3. **`SLA-allegato-sicurezza.md`** → come Allegato B del MSA (parte del contratto)
4. **`informativa-privacy-utenti.md`** → da distribuire agli agenti (obbligo Art. 13 GDPR)
5. **`archibald-security-compliance-overview.md`** → overview tecnica per referente IT Komet

Documenti da AVERE A DISPOSIZIONE (non necessari firma immediata)

6. **`note-legali-ip-titolarita.md`** → se Komet chiede chiarimenti su IP
7. **`docs/compliance/sub-processors.md`** → se Komet chiede lista fornitori
8. **`docs/compliance/incident-response-procedure.md`** → se Komet chiede procedura breach

Demo live da preparare

Demo	Endpoint / Pagina	Nota
Audit log	`GET /api/admin/audit-log`	Mostrare eventi: login, operazioni, security alert
Security alerts panel	Nuovo pannello in AccessManagementPage	Post A.1
AccessManagementPage	`/admin/access`	Ruoli, moduli, MFA status

GDPR erase	`POST /api/admin/customers/:id/gdpr-erase`	Su staging, non produzione
Backup Hetzner	bucket `archibald-backups`	Mostrare file .sql.gz con date
MFA setup flow	Login admin → MFA forced	Live su produzione

Questioni da allineare con Komet al/prima del meeting

Questione	Perché è importante
P.IVA e dati anagrafici Komet Italia	Necessari per compilare tutti i contratti
Komet ha un DPO?	Se sì, i dati del DPO vanno nel DPA e nell'informativa privacy
Gebr. Brasseler firma il MSA o solo Komet Italia?	Se firma Brasseler, potrebbe servire addendum in diritto tedesco. Cambia il foro competente.
Canone mensile	Non definito nel MSA (placeholder). Va concordato prima della firma.
Data decorrenza contratto	Proposta: 1 maggio 2026. Confermare con Komet.
Penetration test: obbligatorio o raccomandazione?	Impatta il placeholder nel SLA.
Canale notifica manutenzione	Per SLA: email? Slack? Altro?

Sezione 4 — Lista Adempimenti Personali di Formicola Francesco

🔴 URGENTE — Entro 7 aprile

#	Adempimento	Come	Stima tempo
1	**Aprire Partita IVA individuale** (libero professionista)	Fisconline.agenziaentrate.gov.it con SPID → modello AA9/12 → ATECO 62.01.09 → Regime forfettario	1-3 giorni
2	**Verificare contratto di lavoro Fresis** — c'è clausola di non concorrenza o esclusiva?	Rileggere il contratto o chiedere al presidente (padre)	1 ora
3	**Comunicare informalmente a Fresis** (= al padre) dell'attività autonoma con Komet, per trasparenza	Conversazione / email informale	-

🟡 ENTRO 10 APRILE

#	Adempimento	Come

4	**Richiedere a Komet** (referente) P.IVA + ragione sociale completa + email DPO (se nominato)	Email al tuo contatto in Komet
5	**Compilare tutti i placeholder** nei 5 documenti contrattuali	Sessione 2 ore con find-and-replace — seguendo lista nel piano C.3
6	**Definire il canone mensile** con Komet prima della firma	Allineamento commerciale — senza questo il MSA non può essere firmato
7	**Decidere** se Gebr. Brasseler è parte del contratto o solo Komet Italia	Email o call con Komet — impatta il foro competente nel MSA
8	**Chiedere a Komet** se hanno preferenze su foro competente (Napoli vs arbitrato CAM Milano)	Facile da risolvere via email

🟡 ENTRO 13 APRILE

#	Adempimento	Come
9	**Stampare** 2 copie di MSA + DPA in versione finale (con placeholder compilati)	Con il tuo codice ATECO: fattura con ritenuta d'acconto 20% se committente italiano
10	**Distribuire l'informativa privacy agli agenti** (obbligatorio Art. 13 GDPR)	Email o sistema interno — la informativa è già pronta in `docs/contracts/informativa-privacy-utenti.md`
11	**Redigere il Registro dei Trattamenti** come Responsabile (1 pagina)	Template nel piano C.1 — non serve consulente per la prima versione
12	**Fare lo DPIA screening** (10 domande)	Template nel piano C.2 — 30 minuti di lavoro

🟢 POST-MEETING / MEDIO TERMINE

#	Adempimento	Quando
13	**Aprire SRLS** per housing del software, liability protection, credibilità corporate	Entro Q3 2026
14	**Consultare commercialista** per gestione contabile della Partita IVA forfettaria	Entro fine aprile
15	**Valutare polizza cyber risk** (copertura responsabilità contrattuale verso Komet in caso di breach)	Entro Q2 2026
16	**Pianificare penetration test** (concordato con Komet come da SLA)	Q3 2026
17	**Verificare con consulente NIS2** se Formicola rientra come "soggetto importante" (D.Lgs. 138/2024)	Entro Q2 2026
18	**Analisi del rischio NIS2** formale (documento separato dal DPIA screening)	Entro Q2 2026

Sezione 5 — Sintesi Visiva: Stato Finale

```
SICUREZZA TECNICA (Art. 32 GDPR / NIS2 Art. 21)
──────────────────────────────────────────────
✅ JWT revocation            ✅ MFA TOTP (volontario)
✅ Audit log immutabile      ✅ GDPR erase (customers + sub_clients)
✅ RBAC + moduli             ✅ Crittografia AES-256-GCM
✅ Backup Hetzner            ✅ Rate limiting (login + mfa-setup/confirm)
✅ CORS + CSP                ✅ Incident response
✅ Security alerts (mailto)  ✅ Portabilità dati
✅ Retention scheduler       ✅ MFA Device Trust (30 giorni)
✅ Admin self-role guard     ✅ CI npm test backend

GOVERNANCE GDPR
───────────────
✅ DPA Art. 28               ✅ Procedura data breach
✅ Informativa Art. 13       ✅ Sub-processor list
⏳ Registro trattamenti      ⏳ DPIA screening
⏳ Informativa agenti        ⏳ Compilazione contratti

CONTRATTI
─────────
✅ MSA struttura             ✅ DPA struttura
✅ SLA con penali            ✅ IP/copyright
❌ Firma                     ❌ Placeholder compilati
❌ Canone definito

INFRASTRUTTURA
──────────────
✅ Branch mergiato           ✅ Migrazioni 046/047/048/049 in prod
✅ Deploy effettuato         ✅ Redis password configurata
❌ Hetzner bucket            ❌ HETZNER_* + alert email nel .env

LEGALE PERSONALE FRANCESCO
──────────────────────────
❌ Partita IVA aperta        ❌ Contratto Fresis verificato
```

Sezione 6 — Checklist Operativa (da spuntare progressivamente)

Entro 7 aprile

- [ ] Aprire Partita IVA individuale (fisconline.agenziaentrate.gov.it, ATECO 62.01.09)
- [ ] Verificare contratto Fresis per compatibilità attività autonoma
- [x] Fix A.1: nodemailer → audit_log + mailto — **deployato in prod 2026-04-05**
- [x] Fix A.2: rate limit /mfa-setup e /mfa-confirm + rimosso `secret` dalla response (solo `uri`)
- [x] Fix A.2b: username nel QR code (getUserById nel MFA middleware)
- [x] Fix A.3: disclaimer note (frontend)
- [x] Fix A.4: Google Fonts verificati — nessun caricamento esterno, self-hosted
- [x] Fix A.8: `npm test` backend aggiunto in CI workflow

- [x] Fix A.11: `DATABASE_PATH` rimosso dal docker-compose.yml
- [x] Fix A.12: guard `actorId !== targetId` su PATCH /users/:id
- [ ] Creare bucket Hetzner Object Storage `archibald-backups`
- [x] **`REDIS_PASSWORD`** — configurata in produzione (2026-04-05)
- [x] **`CORS_ORIGINS=https://formicanera.com`** — configurata in produzione
- [ ] Aggiungere al `.env` VPS: `SECURITY_ALERT_EMAIL`, `HETZNER_BUCKET`, `HETZNER_S3_ENDPOINT`, `HETZNER_ACCESS_KEY`, `HETZNER_SECRET_KEY`

Entro 8 aprile

- [x] Fix A.5: GDPR erase → sub_clients (9 campi: ragione_sociale, pers_da_contattare, email, email_amministraz, telefono, telefono2, telefono3, cod_fiscale, partita_iva) — deployato
- [x] Fix A.6: endpoint portabilità dati — deployato
- [x] Fix A.7: retention scheduler (notifica settimanale, non delete automatico) — deployato
- [x] Fix A.9: gdpr.spec.ts riscritto con assert sul SQL eseguito — deployato
- [x] Fix A.10: `total` count aggiunto alla response di /api/admin/audit-log — deployato
- [x] Migration 046 + 047 + 048 + 049 applicate in produzione (2026-04-05)
- [x] Deploy branch + verifica logs — 5 container healthy
- [ ] Test MFA setup (abilitare MFA per account admin Francesco)
- [ ] Backup manuale + verifica bucket Hetzner (bucket non ancora creato)
- [ ] Configurare cron backup notturno (ore 02:00)

Entro 9 aprile

- [ ] Richiedere a Komet: P.IVA, ragione sociale, email DPO
- [ ] Compilare tutti i 45 placeholder nei contratti
- [ ] Decidere: Gebr. Brasseler nel contratto sì/no?
- [ ] Definire canone mensile con Komet
- [ ] Inviare bozze MSA + DPA a Komet per revisione

Entro 10 aprile

- [ ] Redigere Registro dei Trattamenti (Art. 30.2) — template nel piano
- [ ] DPIA screening (10 domande)
- [ ] Revisione avvocato MSA/DPA (clausole limitazione responsabilità, recesso)

Entro 13 aprile

- [ ] Distribuire informativa privacy agli agenti
- [ ] Stampare 2 copie di MSA + DPA in versione finale
- [ ] Preparare demo live (audit log, security alerts, AccessManagementPage, backup)
- [ ] Verificare che la produzione sia stabile post-deploy

Documento generato il 2026-04-04. Piano di riferimento: `docs/superpowers/plans/2026-04-04-compliance-implementation-plan.md`